INFORME DE EVALUACIÓN DE SEGURIDAD WEB

OWASP ZAP · Gin & Juice Shop

Herramienta	OWASP ZAP 2.17.0
Aplicación evaluada	https://ginandjuice.shop/
Tipo de análisis	Exploración manual, observación del tráfico HTTP y análisis pasivo de alertas
Fecha de las capturas	27–28 de octubre de 2026, según las marcas visibles
Alcance	Documentación de navegación, tráfico observado y alertas visibles. No se documenta explotación de vulnerabilidades.

Informe elaborado a partir de las capturas proporcionadas. Los hallazgos se describen según la información visible en OWASP ZAP y no se presentan como vulnerabilidades explotadas o confirmadas más allá de esa evidencia.

1. Objetivo y alcance

El objetivo es utilizar OWASP ZAP para observar el tráfico HTTP generado al navegar por Gin & Juice Shop, revisar las alertas detectadas y documentar tres alertas de tipos distintos, además de desarrollar una ficha técnica de un hallazgo principal.

El alcance se limita a las acciones y resultados visibles en las capturas: apertura de ZAP, acceso a la aplicación, registro de peticiones y revisión de alertas. No se afirma que se haya ejecutado un escaneo activo ni que se haya explotado una vulnerabilidad.

2. Preparación del entorno

Se instaló OWASP ZAP 2.17.0 en Kali Linux y se abrió la interfaz gráfica. ZAP muestra como proxy principal **localhost:8080**. Firefox mostró una advertencia de confianza del certificado raíz de ZAP durante la inspección HTTPS; posteriormente se aceptó la autoridad certificadora de ZAP para inspeccionar el tráfico HTTPS del laboratorio.

La configuración del navegador debe apuntar al proxy local y al puerto 8080. En las capturas posteriores aparece tráfico del sitio en el historial de ZAP, lo que confirma que las solicitudes estaban llegando a la herramienta.

3. Exploración y tráfico HTTP

Se accedió a **https://ginandjuice.shop/**, una aplicación deliberadamente vulnerable para prácticas de seguridad. El historial registra solicitudes GET a la página principal y a otras rutas, entre ellas catálogo, recursos, cuenta de usuario e inicio de sesión. Las capturas muestran respuestas HTTP 200 OK y una respuesta 302 Found.

Las imágenes demuestran que ZAP observó tráfico de navegación. No permiten afirmar que todas las secciones sugeridas por la guía se exploraran completamente.

4. Análisis de tres alertas

Los niveles de riesgo se reproducen según lo mostrado en la herramienta.

Alerta 1. Content Security Policy (CSP) no configurada

Riesgo: Medio. **URL:** https://ginandjuice.shop/. **Tipo:** configuración de cabecera HTTP. ZAP indica que no está configurada la cabecera Content-Security-Policy. Una CSP permite definir qué fuentes de contenido puede cargar el navegador y puede ayudar a reducir el impacto de ciertos ataques de inyección, incluidos algunos escenarios de XSS. La ausencia de la cabecera no demuestra por sí sola que exista una vulnerabilidad explotable.

Alerta 2. Cookie sin flag HttpOnly

Riesgo: Bajo. **URL:** https://ginandjuice.shop/. **Evidencia:** cookie AWSALB en Set-Cookie, según la captura. ZAP señala que la cookie no incluye HttpOnly. Si una cookie sensible carece de esta protección, JavaScript ejecutado en el mismo origen puede acceder a ella. La relevancia depende del uso de la cookie y del contexto.

Alerta 3. Falta encabezado X-Content-Type-Options

Riesgo: Bajo. **URL:** https://ginandjuice.shop/. **Parámetro:** X-Content-Type-Options. ZAP indica que falta el valor `nosniff`. Se recomienda configurar `X-Content-Type-Options: nosniff` y declarar correctamente el tipo de contenido mediante Content-Type.

Nota metodológica: son observaciones de configuración y análisis pasivo. No equivalen a una prueba de explotación exitosa.

5. Ficha técnica del hallazgo principal

Hallazgo seleccionado: cabecera Content Security Policy (CSP) no configurada.

Elemento	Documentación
1. Nombre de la alerta	Cabecera Content Security Policy (CSP) no configurada.
2. Nivel de riesgo	Medio, según OWASP ZAP.
3. URL o componente	https://ginandjuice.shop/ (página principal observada).
4. Parámetro afectado	Cabecera HTTP Content-Security-Policy.
5. Evidencia	La alerta de ZAP indica que la cabecera CSP no está configurada para la respuesta analizada. La captura muestra URL y riesgo medio.
6. Descripción técnica	Content Security Policy permite indicar al navegador qué fuentes de contenido están autorizadas. Su ausencia elimina una capa de defensa que puede mitigar ciertos escenarios de inyección de contenido.
7. Impacto potencial	Si existiera una vulnerabilidad adicional de inyección, la falta de CSP podría reducir las opciones de mitigación en el navegador. La alerta por sí sola no confirma una explotación.
8. Recomendación	Definir una política CSP adecuada mediante la cabecera HTTP Content-Security-Policy. Restringir las fuentes de scripts y otros recursos según las necesidades de la aplicación; probar la política y validar que no bloquee funciones legítimas.

Validación recomendada: después de configurar la cabecera en el servidor, repetir la navegación y comprobar en las respuestas HTTP que la política se envía correctamente. La configuración debe adaptarse a la aplicación.

6. Conclusiones

La práctica permitió poner en funcionamiento OWASP ZAP en Kali Linux, configurar la inspección HTTPS mediante su certificado raíz y observar solicitudes HTTP generadas al navegar por Gin & Juice Shop. El historial muestra peticiones a varias rutas, confirmando que ZAP recibía tráfico del navegador.

En la pestaña Alertas se observaron avisos sobre configuración de cabeceras HTTP y atributos de cookies. Se documentaron tres alertas: CSP no configurada, cookie sin HttpOnly y ausencia de X-Content-Type-Options. El hallazgo principal fue CSP no configurada, clasificado con riesgo medio por ZAP.

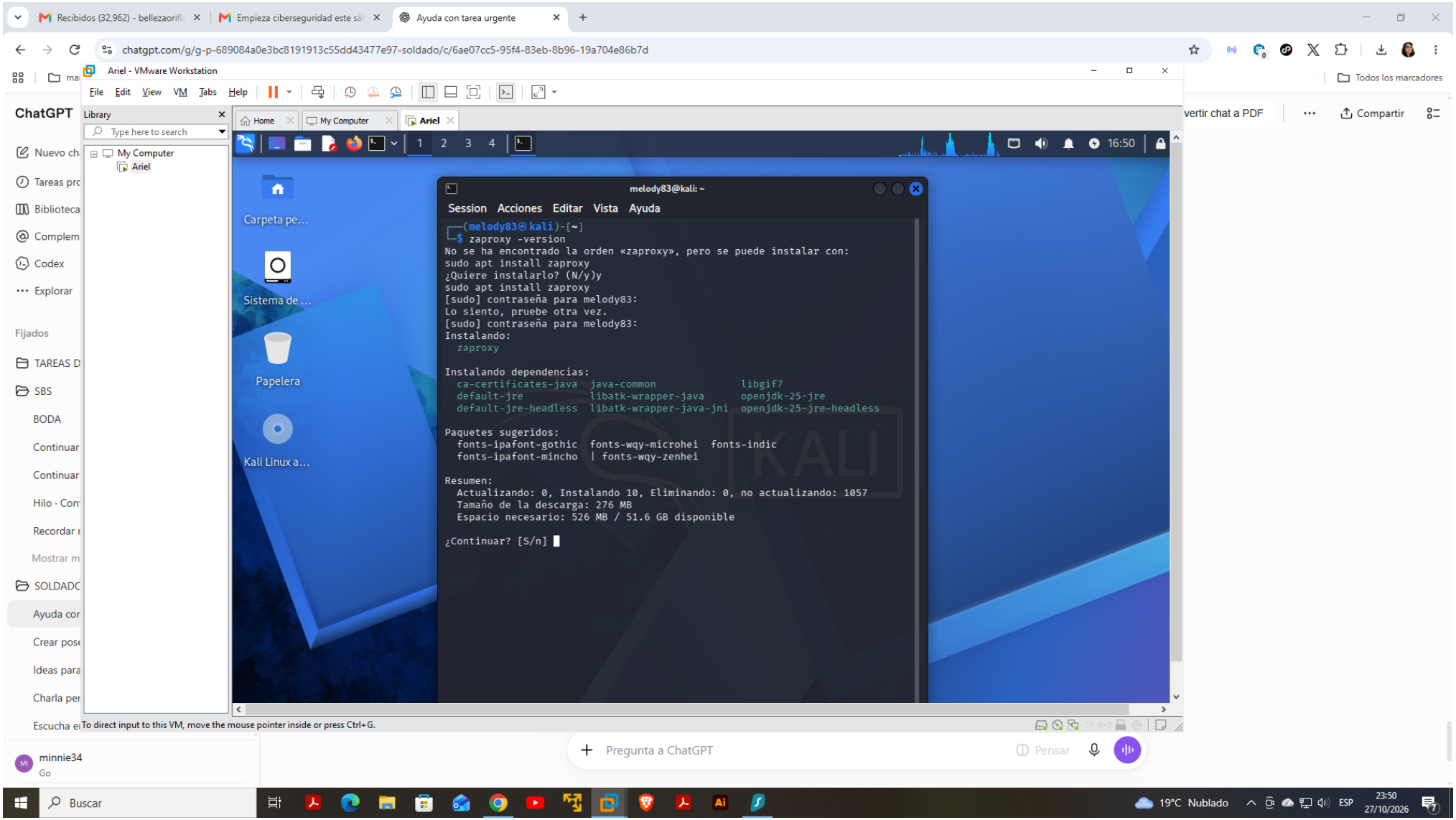
La práctica muestra la importancia de distinguir entre la evidencia de una herramienta y una conclusión sobre la explotabilidad. Las alertas pasivas ayudan a priorizar revisiones y mejoras, pero deben interpretarse en el contexto técnico de la aplicación.

Como siguiente paso, se recomienda revisar otras secciones de la aplicación, conservar capturas del tráfico de cada sección y repetir las pruebas tras aplicar las mejoras. Las pruebas deben realizarse únicamente en sistemas autorizados y dentro del alcance del laboratorio.

7. Evidencias gráficas

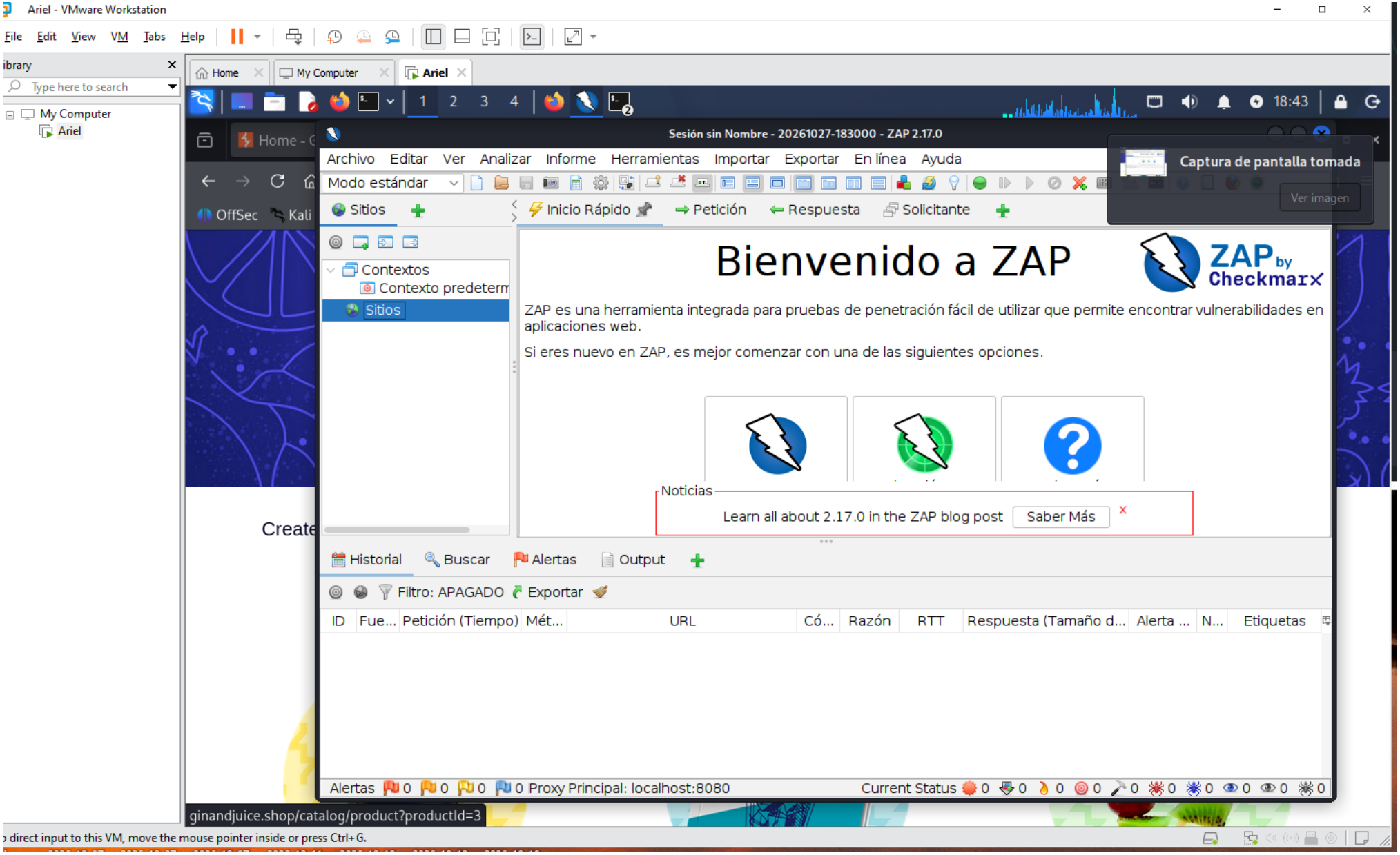
Las capturas siguientes se insertan desde los PNG originales, sin conversión a JPEG ni ampliación artificial. Cada evidencia ocupa una página independiente y mantiene su proporción original.

Anexo 1. Entorno e instalación de ZAP



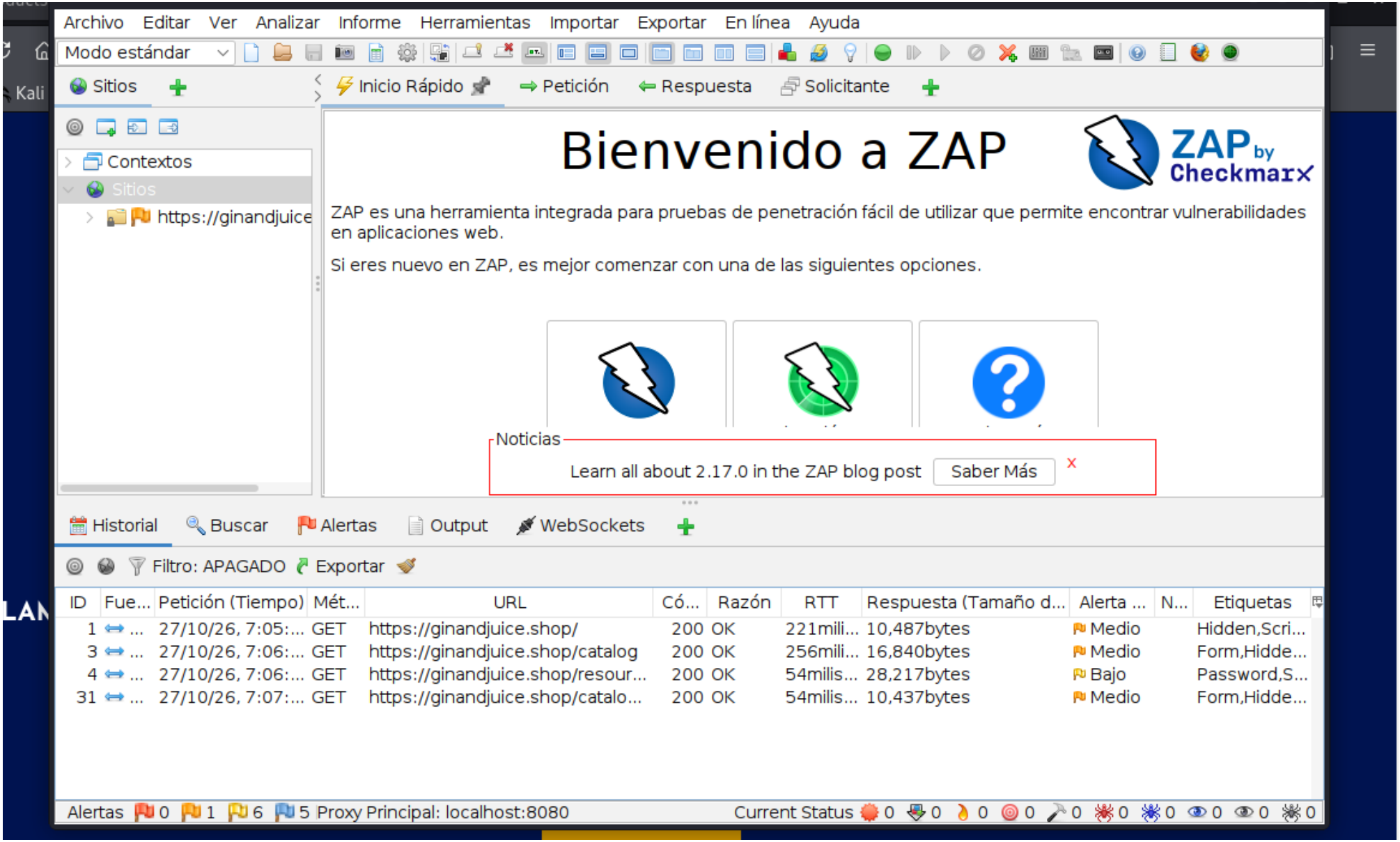
Archivo: image(20261027-225041).png · Resolución original: 1920 × 1080 píxeles.

Anexo 2. Aplicación Gin & Juice Shop en Firefox



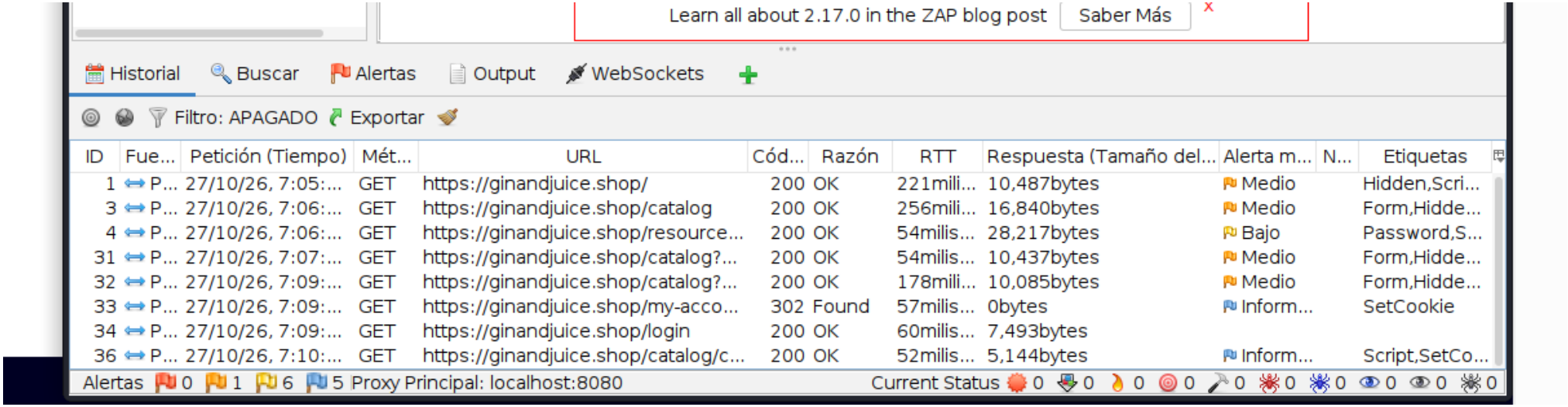
Archivo: image(20261028-004404).png · Resolución original: 1457 × 889 píxeles.

Anexo 3. Historial de peticiones HTTP capturadas



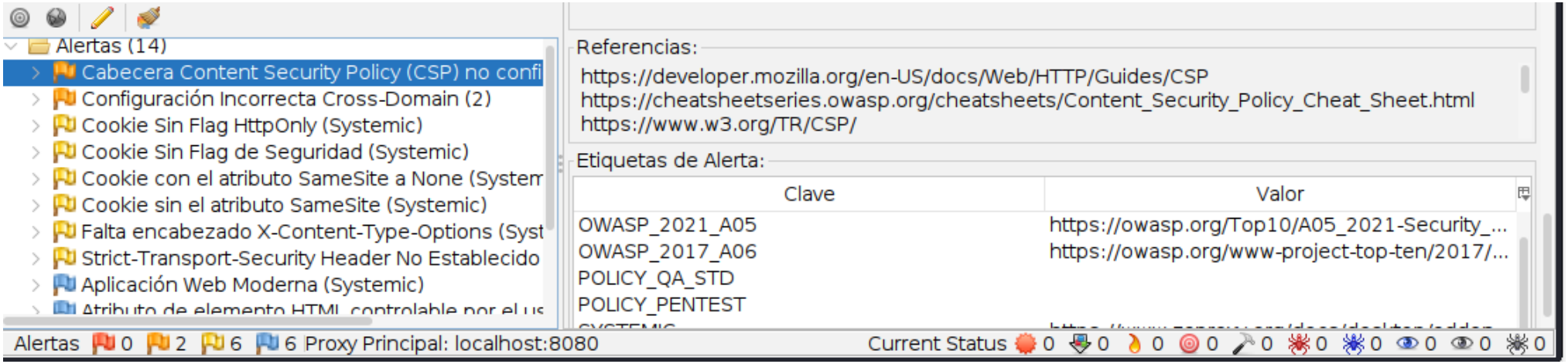
Archivo: image(20261028-010753).png · Resolución original: 1172 × 698 píxeles.

Anexo 4. Lista de alertas de seguridad



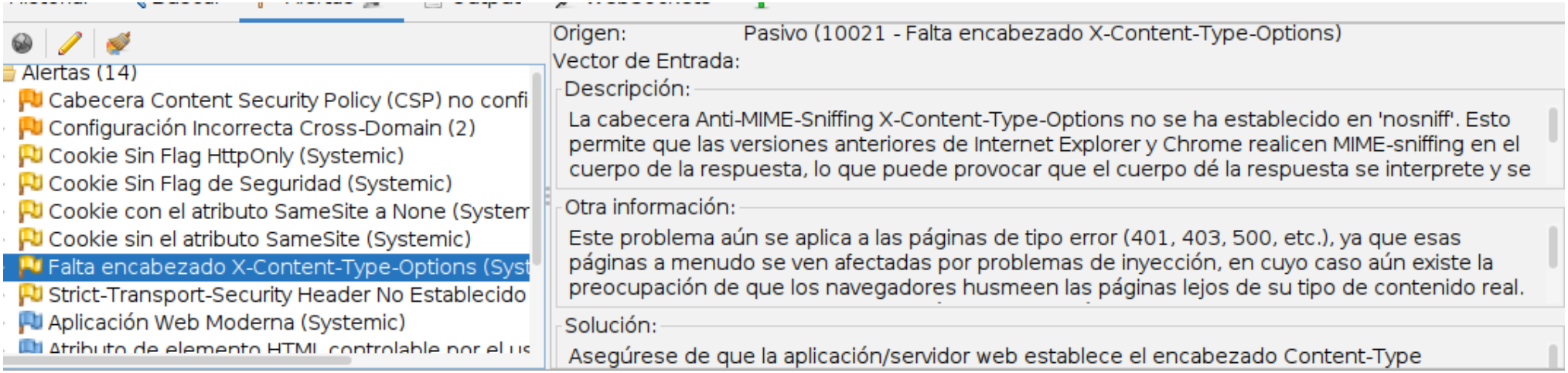
Archivo: image(20261028-011105).png · Resolución original: 1211 × 311 píxeles.

Anexo 5. Detalle de alerta: cabecera CSP no configurada



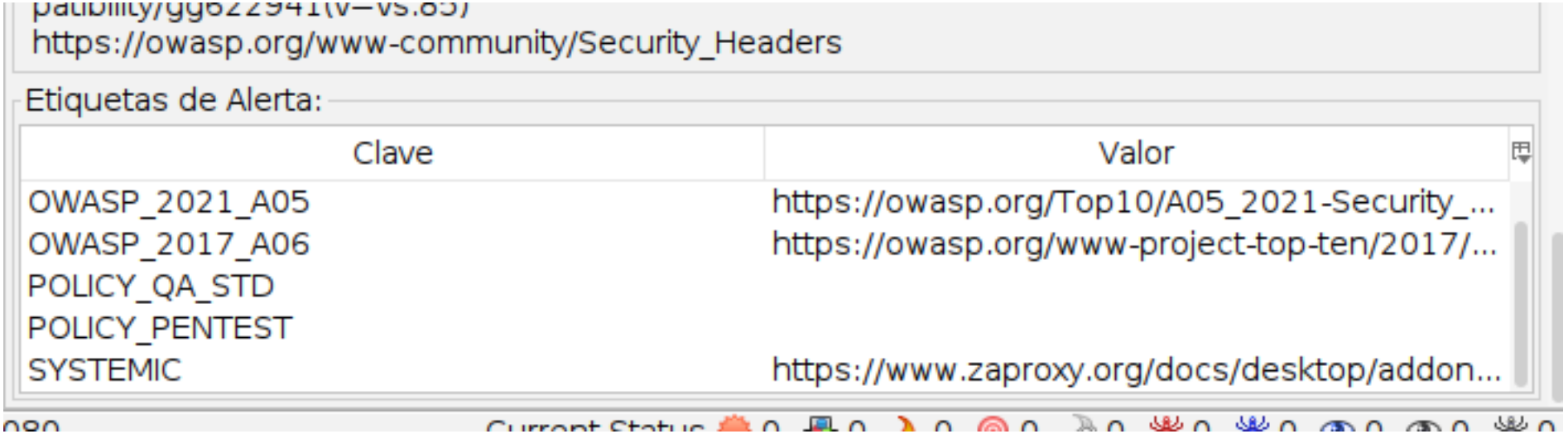
Archivo: image(20261028-015644).png · Resolución original: 1117 × 257 píxeles.

Anexo 6. Detalle de alerta: cookie sin flag HttpOnly



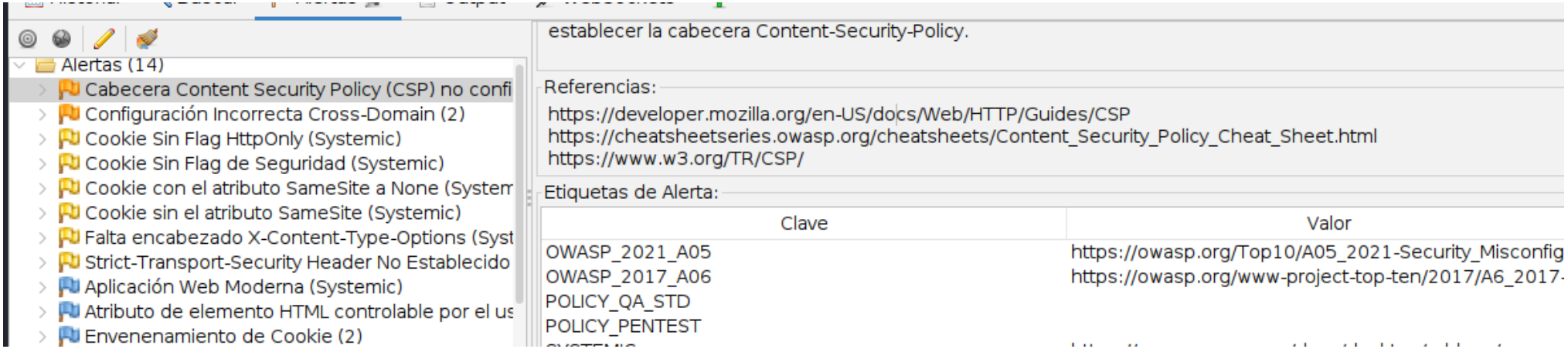
Archivo: image(20261028-012316).png · Resolución original: 1071 × 252 píxeles.

Anexo 7. Detalle de alerta: falta X-Content-Type-Options



Archivo: image(20261028-012421).png · Resolución original: 706 × 194 píxeles.

Anexo 8. Referencias y recomendación de la alerta CSP



Archivo: image(20261028-015921).png · Resolución original: 1203 × 265 píxeles.